

COMP7906B Introduction to Cyber Security

Lecture 2 – Cyber Security Risk Management Overview

Russell Yiu

September 2025

Agenda 1/2

- ISO 31000 Risk Management Framework and Process
- Cyber Security Risk Assessment Objectives
- Cyber Security Risk Assessment/Treatment Overview
- Project Definition
- Project Preparation
 - Business Review
 - Identify Critical Systems and Assets
 - Asset Valuation
 - Threat Identification

Agenda 2/2

- Data Gathering
 - An Overview
 - Administrative Data
 - Physical Data
 - Technical Data
- Risk Analysis and Handling
- Risk Mitigation Analysis
- Reporting

ISO 31000 Risk Management Framework and Process

- Risk management framework – overall structure of the planning and design of the risk management activities
- Risk management process – the implementation of the risk management activities
- The risk management framework guides and assesses the risk management process which in turn assesses the organization's cybersecurity risks
- Risk management framework vs risk management process: <https://pecb.com/whitepaper/iso-31000-risk-management--principles-and-guidelines>

Cyber Security Risk Assessment Objectives

- Ensure due diligence is performed
- Building an understanding of the organization's system and infrastructure
- Provide a basis for establishing proper cyber security policy and procedures
- Provide a basis for selecting and implementing effective safeguards
- Provide a basis for evaluating the effectiveness of current implemented safeguards

Cyber Security Risk Assessment – Key Questions to be Addressed

- What (and where) are the risks?

Risk identification

- What are the current risk levels?

Risk analysis

- Are the current risk levels acceptable?

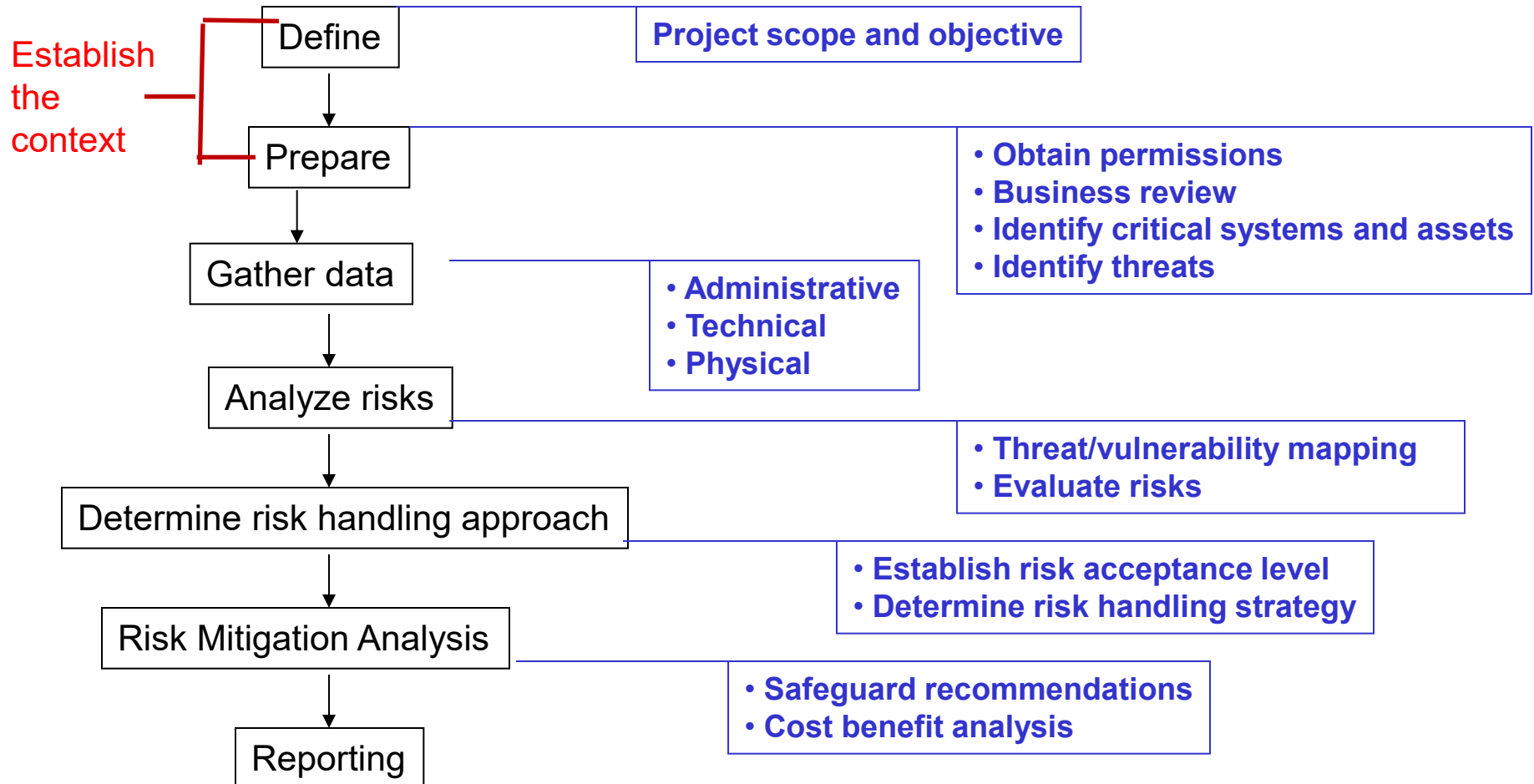
Risk Evaluation

- What does the organization need to do bring the identified risks down to the acceptable level?

Risk Treatment

Cyber Security Risk Assessment/Treatment Overview

- The Process



Project Definition

- Determine the purpose/objective
 - Contract compliance vs program review
- Understand budget and time constraints
- Determine the scope
 - Assets and controls to be included
 - Boundaries of the assessment
- Identify system boundaries

Project Definition

- Limit the Project Scope 1/2

- The project scope is determined by the boundaries of
 - security controls
 - Assetincluded in the project
- Security controls
 - Administrative
 - Policies, procedures, non-technical activities (e.g., exit interviews), technical activities (e.g., audit log review), ..., etc
 - Physical security - controls associated with the protection of the organization's facilities and employees (e.g., security guards, CCTV)
 - Technical security – provides logical protection to assets (e.g., anti-virus software)

Project Definition

- Limit the Project Scope 2/2

- Assets
 - ***Tangible***
 - Physical (e.g. personnel, facilities, systems)
 - ***Intangible***
 - Identifiable, non-monetary assets without physical substance (e.g., intellectual properties, employee safety, customer list, reputation, licensing, etc.)
- System boundaries
 - System type and security requirements
 - Physical (responsibility for physical assets e.g., servers and workstations)
 - Logical (responsibility for the system's data)
 - System interconnections and rationales

Preparation

- Obtain Permission

- Obtain *proper* permission
 - Identify the system owner and obtain permission
 - Who is the actual system owner?
 - Multiple owner situation
 - Shared system
 - Potential violation of legislation
 - Accounts needed for the project
 - Type of account
 - Level of access
 - Reason

Preparation

- Business Review 1/3

- The goals of business review
 - Identify the security requirements
 - Understand the present infrastructure

Preparation

- Business Review 2/3

- Major steps include (see [2])
 - Identify the business objectives
 - Identify the organizational structure
 - Identify the relevant end-users
 - Identify the infrastructure
 - Identify business partners and vendors
 - Identify the competitors
 - Identify trends and standards

Preparation

- Business Review 3/3

- Common approaches
 - Interviews
 - Document review
 - Questionnaire
 - Research

Preparation

- Identify Critical Systems and Assets 1/2

- Goals
 - Identify what needs to be protected
- Identifying information systems
 - Resources boundary
 - Functionalities
 - Data and data owner
 - Authorized users
- Be sure to include both tangible and intangible assets

Preparation

- Identify Critical Systems and Assets 2/2

- Determine system/asset criticality
 - Existing information
 - High level determination
 - Detail classification (e.g., NIST based)
 - Protection requirements: High, Medium, Low
 - Mission criticality: Mission critical, Important, Supportive
 - Define the system: General support system, major application, application

Preparation

- Asset Valuation 1/2

- Approaches
 - Qualitative
 - Quantitative
- The quantitative approach is needed for
 - Budgeting
 - Cost-benefit analysis

Preparation

- Asset Valuation 2/2

- In the quantitative approach
 - Tangible
 - Usually can be readily determined in the form of replacement cost
 - Intangible
 - Data/software replacement cost
 - Information value in terms of
 - Confidentiality
 - Integrity
 - Availability

Preparation

- Threat Identification 1/2

- Threats are events whose occurrences could cause undesirable impact to an organization
- Elements of threats (see [4])
 - *Agent*
 - Something that performs the threat
 - May not be human (e.g. malicious code, nature, etc)
 - *Motive*
 - Something that causes the actions of the threat agent
 - Can be either accidental or intentional
 - *Outcomes* (undesirable)

Preparation

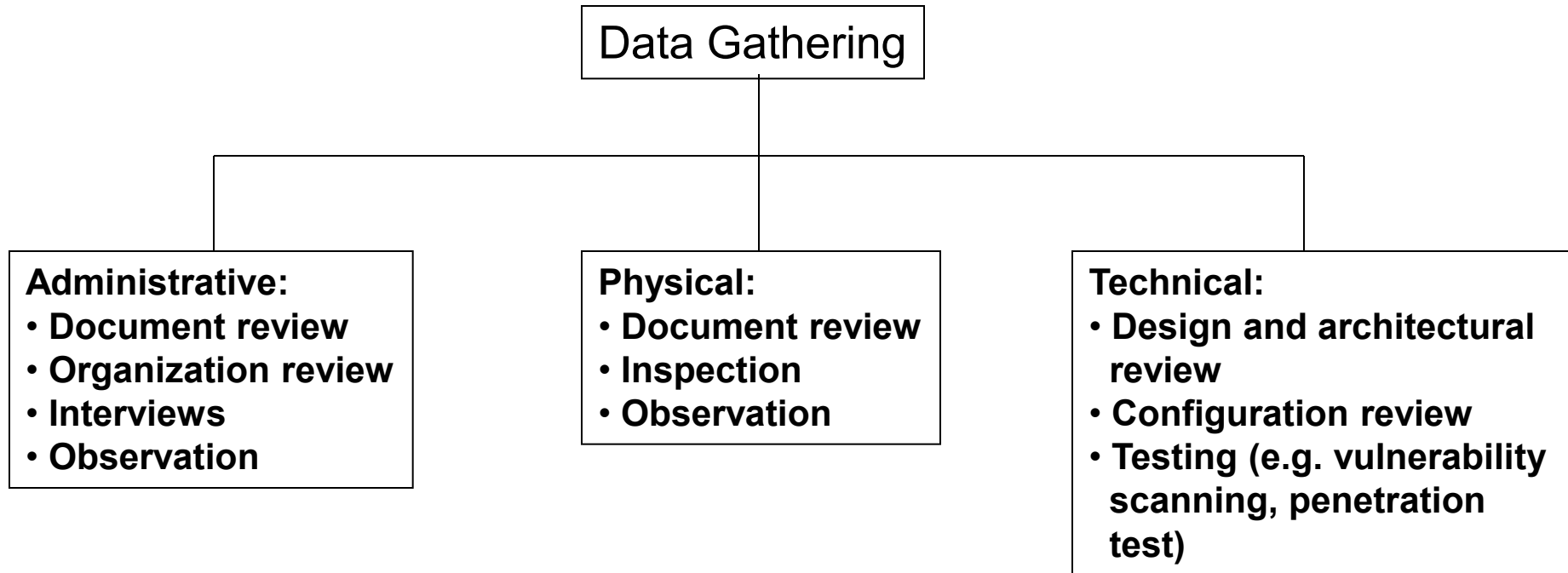
- Threat Identification 2/2

- Two major categories (see [4])
 - Accidental
 - Intentional
- Listing threats
 - Checklist
 - Creating and validating threat statement

Threats must be clearly defined so that all members in the risk assessment team have consistent understanding of the definitions

Data Gathering

- An Overview 1/2



Data Gathering

- An Overview 2/2

- Two major approaches
 - Statistical sampling
 - Sample size can be determined for pre-defined confidence level
 - RIIOT
 - Review
 - Interview
 - Inspect
 - Observe
 - Test

Risk Analysis and Handling

- Steps

- Establish a threat/vulnerability/asset mapping
- Establish a risk metrics
- Perform risk mitigation analysis
- Reporting

Risk Analysis and Handling

- The Threat/Vulnerability/Asset Mapping

- Goal
 - Establish a well-defined measurement on the ramifications of the threats-to-vulnerabilities and the vulnerabilities-to-asset relationship
- Example (oversimplified):

Vulnerability	Relevant Threats	Assets Affected
No anti-virus mechanism implemented	Theft of data	• Reputation • Data confidentiality
	Destruction of data	• Reputation • Data availability
	Modification of data	• Reputation • Data integrity
	...	...

Source: [3]

Risk Analysis and Handling

- Establish a Risk Metrics 1/11

- Goal
 - Prioritize risks
 - Make risk handling decisions
 - Accept
 - Mitigate
 - Transfer
- Approaches
 - Quantitative
 - Qualitative

Risk Analysis and Handling

- Establish a Risk Metrics 2/11

- There are six primitive elements that are usually included in risk metrics (source: [3])
 - ***Asset value***
 - ***Threat frequency***
 - ***Threat exposure factor***
 - ***Safeguard effectiveness***
 - ***Safeguard cost***
 - ***Confidence factor***

Risk Analysis and Handling

- Establish a Risk Metrics 3/11

- Quantitative approach
 - Assign objective numeric values to risk elements and potential losses
 - Objective in nature
- Qualitative approach
 - Use subjective measures (e.g. ordinal ranking)
 - Subjective in nature

Risk Analysis and Handling

- Establish a Risk Metrics 4/11

Quantitative metrics for the primitive risk elements

Risk Element	Value (\$)	Percent (%)	Rate of Occurrence (Annualized)	Range
Asset value	√			√
Threat Frequency			√	√
Threat Exposure Factor		√		√
Safeguard Effectiveness		√		√
Safeguard Cost	√			√
Confidence Factor		√		√

Risk Analysis and Handling

- Establish a Risk Metrics 5/11

Qualitative metrics for the primitive risk elements

Risk Element	Low/Medium/High	Ordinal Ranking	Critical/Important /Nonessential/...
Asset value	√	√	√
Threat Frequency	√	√	
Threat Exposure Factor	√	√	
Safeguard Effectiveness	√	√	
Safeguard Cost	√	√	
Confidence Factor	√	√	

Risk Analysis and Handling

- Establish a Risk Metrics 6/11

Pros and Cons of the quantitative approach

Pros	Cons
• Objective • Easy to understand • Provide a basis for cost-benefit analysis • Can be expressed in professional management language • Performance can be tracked objectively	• Complex and time-consuming • Labor intense • Knowledge based • Lack of common quantification standards • Non-flexible

Risk Analysis and Handling

- Establish a Risk Metrics 7/11

Pros and Cons of the qualitative approach

Pros	Cons
• Simple • No need to quantify asset values, threat frequency, safeguard effectiveness, etc • Easy to involve different level of personals • Flexible	• Subjective • No basis for cost-benefit analysis • Value at risk may not be truly reflected • Performance cannot be tracked objectively

Risk Analysis and Handling

- Establish a Risk Metrics 8/11

- Classical quantitative approach

Single Loss Exposure (*SLE*)

= Asset Value x Exposure Factor

Annualized Loss Expectancy (*ALE*)

= Single Loss Exposure x Annualized Rate of Occurrence
(ARO)

Risk Analysis and Handling

- Establish a Risk Metrics 9/11

- ***Exposure factor (EF)*** measures in terms of a percentage the magnitude of asset value loss as a result of the occurrence of a threat
- ***Annualized rate of occurrence (ARO)*** states the frequency that a threat is expected to occur annually
 - A threat that occurs 2 times every six months has an ARO of 4
 - A threat that occurs 2 times every eight years has an ARO of 0.25

Risk Analysis and Handling

- Establish a Risk Metrics 10/11

- Question: The headquarter of ABC company with value \$3 million is located at an earthquake sensitive area. Suppose there were six earthquakes during the past four years and the exposure factor is estimated to be 60%. Estimate the ALE.

Risk Analysis and Handling

- Establish a Risk Metrics 11/11

- Risk handling criteria can now be established
- Risks that are unacceptable will be identified and risk mitigation analysis will be performed on them to determine
 - What can be done?
 - The costs
 - The effectiveness

Risk Mitigation Analysis 1/4

- Three major steps
 - Select safeguards and perform expected risk mitigation analysis
 - Calculate costs for the recommended safeguards
 - Perform cost-benefit analysis

Risk Mitigation Analysis 2/4

- Select safeguards and perform expected risk mitigation analysis
 - Select safeguard
 - Create safeguard/vulnerability pairs to relevant threats
 - Evaluate the expected risk mitigation
- Automated tools needed for efficiency

Risk Mitigation Analysis 3/4

- Calculate safeguard costs
 - Cost per square foot, installed
 - Average annual cost
 - Annualized maintenance cost
 - Time and materials

Risk Mitigation Analysis 4/4

- Perform cost-benefit analysis
 - Basic idea

Expected risk mitigation value
= ALE before safeguards are applied
- (ALE after safeguards are applied + average
annual costs of the applied safeguards)
 - However, it is not as simple as it looks because the combined effects of all selected safeguards must be represented

Reporting

- A sample risk assessment report may contain
 - Introduction
 - Executive Summary
 - Asset Identification
 - Threat Identification
 - Risk analysis
 - Safeguard Identification
 - Cost-Benefit Analysis
 - Recommendations
 - Appendix

References

- [1] Guide for Mapping Types of Information and Information Systems to Security Categories, NIST Special Publications 800-60, June 2004 available at <http://csrc.nist.gov/publications/nistpubs/800-60/SP800-60V1-final.pdf>
- [2] Juanita Ellis, Timothy Speed, *The Internet Security Guidebook From Planning to Deployment*, Academic Press
- [3] Will Ozier, Risk Analysis and Assessment, Chapter 15 in Harold F. Tipton, Micki Krause, editors, *Information Security Management Handbook*, 4th edition, Auerbach Publications
- [4] Thomas R. Peltier, *Information Security Risk Analysis*, Auerbach Publications